INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC102 INFORMATION SECURITY GOVERNANCE

Security Governance Simulation Assessment

Practical Lab: Social Engineering and Phishing Campaign Simulation

Student Name: Jackline Maina
Reg. No: C11/26/CGRCE/17588
Course: GRC102 – Information Security Governance
Module: Module 9 – Social Engineering Awareness and Security Testing
Tool Used: GoPhish and Mailtrap SMTP
Date: 11/08/2026

Executive Summary

This practical exercise simulated a phishing campaign to evaluate how social engineering attacks can exploit human behavior to gain unauthorized access to organizational resources. Using GoPhish and Mailtrap SMTP, a phishing email and a mock VPN login portal were developed to replicate a realistic phishing scenario. The objective was to assess user susceptibility, understand the stages of a phishing attack, and evaluate the effectiveness of existing security awareness and control measures.

The simulation successfully demonstrated the complete phishing attack lifecycle, including email delivery, user interaction, credential harvesting, and attack monitoring. Results showed how convincing phishing messages can influence users to disclose sensitive information when security awareness is limited. The exercise reinforced the fact that human factors remain one of the most significant cybersecurity risks facing organizations today.

Several key lessons were identified through the simulation. First, regular user awareness training is essential to help employees recognize phishing indicators such as suspicious links, urgent language, and spoofed sender addresses. Second, technical controls such as email filtering, multi-factor authentication (MFA), and web filtering are critical in reducing the likelihood and impact of successful phishing attempts. Finally, effective incident reporting procedures enable organizations to respond quickly and minimize potential damage when phishing activities are detected.

Overall, the practical exercise provided valuable insight into social engineering threats and highlighted the importance of combining user education, security controls, and continuous monitoring to strengthen an organization's security posture. The findings demonstrate that a layered defense strategy is necessary to mitigate phishing risks and improve resilience against cyberattacks.

Objectives

The objectives of this exercise were:

- Understand social engineering attack techniques.
- Design and execute a simulated phishing campaign.
- Measure user interaction with phishing emails.
- Evaluate organizational exposure to phishing attacks.
- Recommend security awareness improvements.

Tools and Environment

Tool	Purpose
GoPhish	Phishing campaign simulation
Mailtrap	SMTP testing and email delivery
Web Browser	Accessing GoPhish interface
Virtual Machine	Controlled testing environment

Methodology

Step 1: GoPhish Installation

GoPhish was deployed within a controlled lab environment and accessed through the administration interface.

Step 2: Sending Profile Configuration

A Mailtrap SMTP profile was configured to support safe email delivery during testing without sending messages to external recipients.

Step 3: Email Template Creation

A phishing email was created to mimic a legitimate VPN access notification requiring users to verify their credentials.

Step 4: Landing Page Configuration

A fake VPN login page was created to simulate credential harvesting techniques used by attackers.

Step 5: Campaign Execution

A phishing campaign was launched against a predefined group of test users.

Step 6: Monitoring Results

Campaign metrics were monitored through the GoPhish dashboard including:

- Emails sent
- Emails opened
- Link clicks
- Credentials submitted

Campaign Results

Metric	Result
Emails Sent	10
Emails Opened	8
Clicks Recorded	5
Credentials Submitted	3
Reporting Rate	2

Risk Analysis

The phishing simulation demonstrated that a portion of users can be persuaded to interact with malicious emails that appear legitimate.

The key risks identified include:

Risk	Impact
Credential Theft	Unauthorized account access
Business Email Compromise	Financial and reputational loss
Malware Infection	System compromise
Data Leakage	Exposure of confidential information
Lateral Movement	Expansion of attacker access

Security Control Assessment

Security Control	Status
Security Awareness Training	Partially Effective
Email Filtering	Effective
User Reporting Process	Needs Improvement
Multi-Factor Authentication	Recommended
Phishing Simulations	Recommended Quarterly

Recommendations

Based on the findings, the following recommendations are proposed:

1. Conduct quarterly phishing awareness simulations.
2. Implement mandatory security awareness training.
3. Enforce Multi-Factor Authentication (MFA) for all critical systems.
4. Improve email filtering and anti-phishing controls.
5. Establish an easy-to-use phishing reporting mechanism.
6. Monitor phishing trends and continuously update awareness content.

Lessons Learned

This exercise demonstrated that human users remain a significant target for cybercriminals. Even with technical controls in place, phishing attacks continue to pose a substantial risk. Regular awareness campaigns and user education are critical components of an effective security program.

The simulation also provided practical experience in planning, executing, and evaluating phishing assessments using industry-standard tools.

Conclusion

The phishing campaign simulation successfully achieved its objectives by demonstrating how social engineering attacks can influence user behavior and compromise organizational security. The results underscore the importance of combining technical controls with ongoing security awareness initiatives. Organizations that regularly test and educate users are better positioned to detect and prevent phishing attacks before they result in a security incident.